RESULTADO DA COMPARAÇÃO — TESTE 03 (fiware/orion)

Terceira rodada de avaliação comparativa. Modelos avaliados: Granite 4.2, DeepSeek R1 e Qwen 3.5. Referência: análise de controle (`ANALISE_CONTROLE_TESTE03.md`) construída a partir do relatório do Trivy desta rodada, antes da leitura dos PDFs. Nenhuma fonte externa foi utilizada.

---

1. Dados da coleta e da preparação

1.1 Relatório do Trivy (dados brutos)

Item	Valor
Comando	`trivy.exe image -f json -o TRIVY_FIWARE_ORION_TESTE03.json fiware/orion`
Versão do Trivy	0.74.0 (banco `trivy-db:2`, atualizado em 2026-10-19 19:08 UTC)
Execução	2026-10-19T18:22:33-03:00 a 2026-10-19T18:23:05-03:00 (`CreatedAt` 2026-10-19T18:23:04-03:00)
Imagem	`fiware/orion:latest`, digest `sha256:dc29ec56…96edf`, criada em 2026-04-14, Debian 13.4
`Results`	1 (os-pkgs, debian)
Ocorrências de vulnerabilidade	6.663
Por `Severity`	CRITICAL 12 · HIGH 820 · MEDIUM 4.439 · LOW 1.044 · UNKNOWN 348
Por `Status`	fixed 5.522 · affected 1.138 · fix_deferred 2 · will_not_fix 1

1.2 Preparação reproduzida (remoção de `Status = fixed`)

Item	Valor
Antes da remoção	6.663
Removidas (fixed)	5.522
Restantes	1.141 (936 IDs distintos, 60 pacotes)
Por `Severity` após remoção	CRITICAL 3 · HIGH 115 · MEDIUM 604 · LOW 373 · UNKNOWN 46
Por `Status` após remoção	affected 1.138 · fix_deferred 2 · will_not_fix 1
Restantes com `FixedVersion`	0

1.3 Diferença entre a preparação descrita e a entrada evidenciada pelos PDFs

Os três PDFs registram, no cabeçalho gerado pelo harness, **"Blocos analisados: 11"** e **"Vulnerabilidades descartadas (FIXED): 654"**. O conteúdo das onze partes, em todos os três relatórios, cita exclusivamente ocorrências de severidade HIGH e uma CRITICAL (CVE-2026-43185), e várias partes afirmam contagens de dez itens por parte ("Total de Vulnerabilidades Detectadas: 10", "10 CVEs classificados com Gravidade HIGH"). A reconstrução das partes a partir dos três PDFs (que coincidem entre si na composição de cada parte) resulta em **109 ocorrências** — 10 por parte nas partes 1 a 10 e 9 na parte 11 — todas HIGH/CRITICAL e todas sem `FixedVersion`.

Conclusão registrada sem alterar os dados atuais: a entrada efetivamente processada pelos modelos no Teste 03 foi um relatório **filtrado por severidade HIGH/CRITICAL** (654 fixed removidas de um total aproximado de 763), e não o

relatório completo descrito na Etapa 2. O conjunto completo desta rodada tem 1.141 ocorrências restantes; o subconjunto comparável (HIGH/CRITICAL não corrigidas) tem **118 ocorrências**.

Correspondência entre a entrada reconstruída (109) e o subconjunto comparável atual (118):

Grupo	Entrada reconstruída	Atual (HIGH/CRITICAL não corrigidas)	Situação
Pacotes de espaço de usuário (util-linux ×9 pacotes, curl ×2, libacl1, systemd ×2, ncurses ×3, perl-base)	47	47	Idênticos: mesmos IDs, pacotes e versões
linux-libc-dev presentes em ambas	51	51	Idênticos
linux-libc-dev apenas na entrada original	11	—	Constam do JSON atual com `Status = fixed` (FixedVersion 6.12.113-1): CVE-2025-38204, CVE-2026-72463, 89633, 89638, 89972, 97528, 98222, 98260, 98320, 98323, 98378
linux-libc-dev apenas no JSON atual	—	20	Incluem CVE-2026-63825 e CVE-2026-93221 (CRITICAL); não estavam disponíveis aos modelos

Para os 11 IDs do kernel que hoje constam como corrigidos, há evidência suficiente de presença na execução original (citados de forma consistente pelos três modelos e presentes no JSON atual com título e descrição), de modo que os campos `Title`/`Description` do JSON atual são usados como referência; a diferença de `Status` entre execuções é registrada e não é atribuída aos modelos. Os 20 IDs presentes apenas no JSON atual não são cobrados dos modelos.

Verificação auxiliar: o relatório HIGH/CRITICAL do Trivy da rodada anterior (`Analise-2/TRIVY_FIWARE_ORION_HIGH_CRITICAL.json`, 2026-09-20, mesma imagem) foi conferido apenas para testar se seria a entrada original; apresenta 579 fixed e 145 restantes, portanto **não** é a entrada do Teste 03. Nenhuma outra fonte foi consultada.

1.4 Composição das partes (reconstruída a partir dos PDFs)

Parte	Conteúdo evidenciado
1	bsdutils (CVE-2026-76642, 78408, 78409, 78410); curl (CVE-2026-12064, 8458); libacl1 (CVE-2026-54369); libblkid1 (76642, 78408, 78409)
2	libblkid1 (78410); libcurl4t64 (12064, 8458); liblastlog2-2 (76642, 78408, 78409, 78410); libmount1 (76642, 78408, 78409)
3	libmount1 (78410); libsmartcols1 (×4); libsystemd0 (CVE-2026-16742); libtinfo6 (CVE-2025-69720); libudev1 (16742); libuuid1 (76642, 78408)
4	libuuid1 (78409, 78410); linux-libc-dev: CVE-2026-43185 (CRITICAL), CVE-2013-7445, 2019-19449, 2019-19814, 2021-3847, 2021-3864, 2024-21803, 2024-58015
5	linux-libc-dev: CVE-2025-38137, 38187, 38204, 38421, 38636, 39859, 39862, 39958, 40025, 68174
6	linux-libc-dev: CVE-2025-68735, CVE-2026-23102, 23208, 23327, 31493, 31536, 31568, 43263, 46130, 46181
7	linux-libc-dev: CVE-2026-46279, 52991, 53000, 53091, 53109, 53118, 53277, 53330, 63879, 64283
8	linux-libc-dev: CVE-2026-68409, 68426, 68470, 72042, 72098, 72463, 74269, 74520, 74752, 89631
9	linux-libc-dev: CVE-2026-89633, 89638, 89675, 89811, 89972, 90111, 90315, 97528, 98222, 98260
10	linux-libc-dev: CVE-2026-98320, 98323, 98364, 98378; login (76642, 78408, 78409, 78410); mount (76642, 78408)

Parte	Conteúdo evidenciado
11	mount (78409, 78410); ncurses-base e ncurses-bin (CVE-2025-69720); perl-base (CVE-2026-9538, `fix_deferred`); util-linux (×4)

Observação: a divisão seguiu a ordem alfabética de `PkgName` do JSON, separando os 9 pacotes binários do util-linux em cinco partes diferentes (1, 2, 3, 4, 10 e 11) e o kernel em sete partes (4 a 10).

1.5 Referência utilizada para a avaliação

Dado o exposto, a avaliação de cobertura e precisão usa como referência a entrada reconstruída (109 ocorrências HIGH/CRITICAL, 10 por parte), confrontada com os campos do JSON atual (`Title`, `Description`, `Severity`, `Status`, `InstalledVersion`, `FixedVersion`, `CVSS`). A análise de controle, construída sobre as 1.141 ocorrências, permanece como referência para impacto e recomendações; suas seções 3.1 a 3.3 (CRITICAL e HIGH) correspondem ao universo visto pelos modelos. A omissão de itens MEDIUM/LOW/UNKNOWN **não** é cobrada de nenhum modelo, porque esses itens não lhes foram apresentados.

Fatos do controle diretamente relevantes para as três avaliações:

- Nenhuma das ocorrências apresentadas aos modelos possuía `FixedVersion`; todas tinham `Status = affected`, exceto CVE-2026-9538 (perl-base, `fix_deferred`).
- As descrições do util-linux, libacl1, systemd-homed, ncurses (`infocmp`) e dos CVEs antigos do kernel (2021-3847, 2021-3864) explicitam cenário **local**.
- A imagem executa como `User = nobody`; o pacote vulnerável do kernel é `linux-libc-dev` (arch `all`); nenhum pacote `linux-image` consta do relatório.

Granite 4.2

Critério	Nota
Vulnerabilidades relevantes	7/10
Impacto provável	7/10
Recomendações de correção	5/10
MÉDIA FINAL	6,33/10

Justificativa das notas

Vulnerabilidades relevantes — 7. Cobertura completa: as 109 ocorrências da entrada reconstruída aparecem nas partes correspondentes, com `PkgName` e `InstalledVersion` corretos e com tratamento explícito das repetições (o modelo identifica que o mesmo CVE aparece em vários pacotes binários e lista uma vez por ID, indicando os pacotes). A severidade é usada corretamente (todas HIGH; CVE-2026-43185 destacada como CRITICAL na parte 4). Dois fatores reduzem a nota: (i) na parte 8, o modelo interpreta o texto padrão das descrições do kernel ("the following vulnerability has been resolved") como indicação de que a versão instalada 6.12.74-2 já contém as correções, contrariando `Status = affected` de todas as entradas; (ii) o campo `Status = fix_deferred` de CVE-2026-9538 não é mencionado. Além disso, o relatório inclui o raciocínio interno do modelo em inglês antes de cada resposta final (o PDF tem 40 páginas, contra 14 e 16 dos demais), o que prejudica a clareza da apresentação solicitada como "concisa e direta".

Impacto provável — 7. Os impactos derivam das descrições e são, em geral, proporcionais: distinção entre exploração local e remota ("Todos os casos são HIGH e exploráveis localmente sem acesso remoto", parte 3),

condicionamento a `fstab` e opções `X-mount`, menção a cenários de depuração (KASAN, `CONFIG_MEM_ALLOC_PROFILING_DEBUG`) presentes na descrição de CVE-2026-46279, e observação de que o impacto das falhas de kernel depende de o container usar o kernel do hospedeiro (partes 7 e 8), ponto que o relatório não permite verificar mas que o modelo apresenta como condição, não como fato. Reduzem a nota: a conclusão da parte 8 de que o impacto estaria "mitigado se patchado" e que as CVEs "são fixes já resolvidos"; a afirmação na parte 2 de que "os problemas são de código e não de configuração", contraditória com as próprias recomendações de revisão de `fstab` nas partes 1 e 4; e algumas generalizações ("possível execução remota de código") sem base na descrição.

Recomendações de correção — 5. Há recomendações bem sustentadas pelas descrições: evitar URLs sem esquema com `--proto-default sftp/scp` (CVE-2026-12064), auditar e restringir entradas `X-mount.*` em `fstab`, isolar o serviço em container com volumes somente leitura, garantir que o **hospedeiro** esteja corrigido (único modelo a fazê-lo), evitar montagens CIFS com `cifsacl`/`modefromsid` e cópia assíncrona em NFS (parte 9). Contudo, o modelo apresenta repetidamente versões-alvo que não constam dos dados e são inconsistentes entre partes: util-linux ">2.41.5" (parte 1), "≥2.42.3" (parte 3), "≥2.41.6" (parte 11); "libcurl >8.14.1" (parte 2, sendo 8.14.1 a versão já instalada); "login ≥ 1:4.16.0-2+really2.42+" e "linux-libc-dev ≥ 6.12.74-2+fixes" (parte 10); "kernel ≥ 6.5" (parte 9, inferior ao 6.12 instalado). Afirma que "Debian 13.4 já inclui fixes para esses CVEs" (parte 10) e que "a atualização resolve todas as CVEs mencionadas" (parte 6), sem `FixedVersion` nos dados. Cita o codinome "Bookworm" para Debian 13.4 (partes 5 e 9), informação ausente dos dados. Recomenda "preferir AT_SYMLINK_FOLLOW em vez de AT_SYMLINK_NOFOLLOW" (parte 4), que não corresponde a nenhuma ação executável descrita nos dados, e a opção "no_new_perm". Na parte 8, orienta "verificar se a versão 6.12.74-2 já inclui os fixes (geralmente sim)".

Principais acertos

- Cobertura integral das 109 ocorrências, com pacotes e versões corretos em todas as partes.
- Tratamento explícito e correto das repetições do mesmo CVE em vários pacotes binários.
- Distinção local/remoto e condicionamento do impacto aos pré-requisitos descritos (`fstab`, `X-mount`, depuração ativa).
- Observação de que falhas de kernel dependem do kernel do hospedeiro e de que a correção não pode ser feita apenas dentro do container (partes 7 e 8).
- Mitigações de configuração derivadas das descrições (URLs com esquema explícito, restrições a `X-mount`, opções CIFS/NFS, isolamento).
- Versões-alvo corretamente derivadas das descrições em três casos: ncurses "6.5-20251213" (descrição: "before 6.5-20251213"), libacl "2.4.0" (descrição: "before version 2.4.0"), Archive::Tar "3.10" (descrição: "before 3.10").

Principais limitações

- Exposição do raciocínio interno em inglês em todas as partes, com tentativas, correções e repetições, em contradição com a instrução de concisão; a resposta útil ocupa fração pequena do relatório.
- Leitura incorreta do status na parte 8 (versão instalada tratada como possivelmente já corrigida).
- Versões-alvo inventadas ou inconsistentes entre partes; afirmação de disponibilidade de correção sem suporte nos dados.
- Codinome de distribuição incorreto e ausente dos dados.
- Ausência de menção ao `Status = fix_deferred` do perl-base.

Divergências observadas

Parte	Conteúdo apresentado pelo modelo	Dado de referência	Classificação
1	"versões mínimas seguras para util-linux são >2.41.5"	Descrição de CVE-2026-76642: "versions through 2.41.5 and 2.42.2" vulneráveis; sem `FixedVersion`	PARCIALMENTE SUSTENTADA (ignora o ramo 2.42)
1	"libacl >2.4.0"	Descrição de CVE-2026-54369: "acl before version 2.4.0"	SUSTENTADA PELOS DADOS (versão upstream, não versão Debian)
2	"libcurl >8.14.1" como versão segura	`InstalledVersion` 8.14.1-2+deb13u2; sem `FixedVersion`	NÃO SUSTENTADA PELOS DADOS
2	"os problemas são de código e não de configuração; não há mitigação adicional"	Descrições condicionam exploração a `fstab` / `X-mount` / `--proto-default`	CONTRADITÓRIA AOS DADOS
3	"util-linux ≥2.42.3"	Descrição: "through 2.41.5 and 2.42.2"	PARCIALMENTE SUSTENTADA (inferência coerente, não é dado)
3	"ncurses ≥6.5-20251213"	Descrição de CVE-2025-69720: "before 6.5-20251213"	SUSTENTADA PELOS DADOS
4	"Preferir AT_SYMLINK_FOLLOW em vez de AT_SYMLINK_NOFOLLOW"	Descrição de CVE-2026-78409 menciona `AT_SYMLINK_NOFOLLOW` como insuficiente; não propõe alternativa de flag	NÃO SUSTENTADA PELOS DADOS
5, 9	"Debian Bookworm (13.4)"	`Metadata.OS` = debian 13.4; codinome não consta	NÃO SUSTENTADA PELOS DADOS
6	"a atualização para a versão mais recente do kernel/libc do Debian resolve todas as CVEs mencionadas"	Nenhuma entrada com `FixedVersion`	NÃO SUSTENTADA PELOS DADOS
8	"Todas as CVE listadas são fixes já resolvidos no kernel; verificar se 6.12.74-2 já inclui os fixes (geralmente sim)"	`Status = affected` em todas; texto "has been resolved" é boilerplate da descrição upstream	CONTRADITÓRIA AOS DADOS
9	"kernel ≥ 6.5 se disponível"	`InstalledVersion` 6.12.74-2	CONTRADITÓRIA AOS DADOS
10	"login ≥ 1:4.16.0-2+really2.42+", "linux-libc-dev ≥ 6.12.74-2+fixes", "Debian 13.4 já inclui fixes"	Sem `FixedVersion`; versões não constam	NÃO SUSTENTADA PELOS DADOS
11	"util-linux ≥2.41.6"	Descrição: "through 2.41.5 and 2.42.2"	PARCIALMENTE SUSTENTADA
11	"perl-Archive-Tar ≥3.10"	Descrição de CVE-2026-9538: "versions before 3.10"	SUSTENTADA PELOS DADOS
9	Impactos por CVE da parte 9 (SMB client OOB, setuid em CIFS, nfsd UAF, TLB/GPU, NVMe SRCU, ip6mr, lockdown PCI, qla2xxx, KEYS overflow, timers POSIX)	IDs hoje `fixed` no JSON atual; títulos/descrições coincidem	SUSTENTADA PELOS DADOS (status diverge entre execuções)

Omissões relevantes

- `Status = fix_deferred` de CVE-2026-9538 (perl-base) não é mencionado (parte 11).
- Não há indicação, em nenhuma parte, de que os dados não trazem versão corrigida para nenhuma ocorrência; o modelo preenche a lacuna com versões próprias.

- Não observa que `linux-libc-dev` é pacote de desenvolvimento nem sugere sua remoção (nenhum modelo o fez).

Informações adicionais apresentadas pelo modelo

Informação	Classificação
Dependência do kernel do hospedeiro para o impacto das falhas de kernel em container	Não verificável pelos dados; coerente com `PkgName = linux-libc-dev` e ausência de `linux-image` no relatório
Referências a "security.debian.org", "NVD/DEB advisories", "security.debian.net"	Não constam dos dados; o último domínio não corresponde ao padrão dos demais
"GROUP_CREATE/GROUP_DESTROY", "divide error", KASAN, "sem risco para impressão" (CVE-2025-38636)	SUSTENTADAS: termos presentes nas descrições de CVE-2025-68735, CVE-2025-68174, CVE-2026-46279 e CVE-2025-38636
Opção "no_new_perm"	NÃO SUSTENTADA (não consta dos dados)

Síntese

Granite 4.2 foi o modelo com melhor fidelidade na identificação e no tratamento das repetições, e o único a situar o impacto das falhas de kernel na dependência do hospedeiro. A qualidade das recomendações, porém, é comprometida por versões-alvo inventadas e inconsistentes, por afirmações de disponibilidade de correção sem suporte e pela leitura invertida do status na parte 8. A exposição do raciocínio interno contraria a instrução de concisão e reduz a utilidade prática do relatório. Há informações apresentadas como fato sem suporte nos dados (versões-alvo, codinome, disponibilidade de correção), o que justifica o termo "alucinação" para esses pontos específicos.

Resultado

NÃO SATISFATÓRIO (média 6,33 < 7,00)

DeepSeek R1

Critério	Nota
Vulnerabilidades relevantes	5/10
Impacto provável	5/10
Recomendações de correção	5/10
MÉDIA FINAL	5,00/10

Justificativa das notas

Vulnerabilidades relevantes — 5. Nas partes 1, 2, 4, 6, 8 e 10 a listagem é completa ou quase completa e as associações ID–pacote estão corretas; na parte 1 o modelo lista os pacotes de cada CVE (bsdutils, libblkid1). Porém a cobertura cai de forma acentuada em outras partes: parte 3 omite CVE-2025-69720 (libtinfo6) e as entradas de libuuid1; parte 5 lista 8 de 10 (omite CVE-2025-39958 e deixa CVE-2025-38636 fora da lista, citando-a apenas no impacto); parte 7 lista 3 de 10; parte 9 lista 3 de 10; parte 10 omite CVE-2026-98323 e CVE-2026-98378; parte 11 omite CVE-2026-78408. No total, 19 das 109 ocorrências não aparecem na parte em que foram apresentadas (17%), concentradas nas partes 7 e 9. Há ainda erros de representação: na parte 3, "CVE-2026-16742 … do systemd-

homed (via util-linux e libudev1)" associa indevidamente util-linux; na parte 4, CVE-2026-43185 é descrita como "vulnerabilidade crítica de assinatura de dados no SMB", quando o título é "signededness bug" (sinal de inteiro); na parte 11, CVE-2026-9538 (perl-base) é descrita como "buffer overflow … via entrada maliciosa no comando infocmp", conflitando-a com CVE-2025-69720 (ncurses). O `Status = fix_deferred` não é mencionado. A severidade é por vezes inflada ("Essas vulnerabilidades são críticas", partes 1 e 5), embora todos os itens sejam HIGH.

Impacto provável — 5. Quando segue a descrição, o impacto é adequado (parte 2, com um parágrafo por CVE do util-linux e do libcurl; parte 6, com mapeamento subsistema a subsistema). Porém há várias conclusões sem suporte ou contraditórias: "local ou, em alguns casos, remoto se Orion for exposto" para o util-linux (parte 1; descrições indicam usuário local não privilegiado); "ataques como devoxy (supersede de credenciais)" (termo sem correspondência nos dados); "execução remota de código" atribuída a CVE-2026-46279 (mm/alloc_tag), CVE-2026-68409 e 68470 (mac80211), CVE-2026-72098 (dm-verity) e CVE-2026-89675 (nfsd), cujas descrições tratam de UAF/overflow sem indicação de vetor remoto; "escalada de privilégios" atribuída a CVE-2026-31493 (RDMA/efa, leitura de contexto liberado); e os dois erros de caracterização já citados (43185 e 9538). A nota da parte 7 ("datas 2026 podem indicar versões futuras do kernel") é especulação não sustentada.

Recomendações de correção — 5. O modelo evita, na maior parte, inventar versões: recomenda "atualizar para versões que corrigem" e, na parte 7, registra que "não há correção específica de pacote para linux-libc-dev nesta CVE", observação coerente com a ausência de `FixedVersion`. Inclui medidas operacionais razoáveis (testar após atualizar, backup, isolamento, monitoramento). Contudo: na parte 11 recomenda `apt-get install util-linux=2.42.*`, versão que a descrição indica como vulnerável até 2.42.2; `perl-base=5.40.*` não distingue da versão instalada 5.40.1-6; sugere `--allow-downgrades` para obter versões mais recentes (parte 1); recomenda "KASAN" como "ferramenta de mitigação" (parte 6), quando a descrição o apresenta como instrumento de depuração que revela a falha; propõe correções em nível de código-fonte do kernel ("estender o bloqueio do cgroup_mutex", "tratar offset e tamanho como loff_t", parte 7), inaplicáveis a quem opera a imagem; cita "newfs" como processo relacionado ao util-linux (parte 3), sem base nos dados. A recomendação `ncurses-bin=6.5-20251213+` (parte 11) é sustentada pela descrição. A revisão de `fstab`/`X-mount`, central nas descrições do util-linux, aparece apenas de forma indireta ("Monitore Cgroups", "Limitação de Capabilities").

Principais acertos

- Partes 2 e 6: impacto e recomendação por CVE, fiéis às descrições.
- Reconhecimento, na parte 7, de que não há correção de pacote disponível para as CVEs do kernel.
- Cautela com CVEs antigos ("deve ser verificada se ainda está presente", parte 4) e com dependências do Orion antes de atualizar.
- Associação correta de `login`/`mount` ao util-linux na parte 10.
- Versão de ncurses derivada da descrição (6.5-20251213).

Principais limitações

- Perda de cobertura nas partes 3, 5, 7, 9, 10 e 11 (19 ocorrências ausentes), com partes 7 e 9 reduzidas a 3 de 10 IDs.
- Caracterizações incorretas de CVE-2026-43185 e CVE-2026-9538.
- Impactos "remotos" e de "escalada" não sustentados pelas descrições.
- Versão-alvo `2.42.*` contraditória com a descrição; KASAN como mitigação.
- Nenhuma menção a `fix_deferred`; severidade HIGH tratada como "crítica".

Divergências observadas

Parte	Conteúdo apresentado pelo modelo	Dado de referência	Classificação
1	Exploração "remota se Orion for exposto" para CVE-2026-76642/78408/78409/78410	Descrições: "unprivileged users", "local unprivileged user"	NÃO SUSTENTADA PELOS DADOS
1	"ataques como devoxy (supersede de credenciais)"	Sem correspondência nos dados	NÃO SUSTENTADA PELOS DADOS
3	"systemd-homed (via util-linux e libudev1)"	CVE-2026-16742 pertence a libsystemd0/libudev1; util-linux não consta	CONTRADITÓRIA AOS DADOS
3	"restringir … processos relacionados ao util-linux (como newfs)"	"newfs" não consta dos dados	NÃO SUSTENTADA PELOS DADOS
4	CVE-2026-43185: "vulnerabilidade crítica de assinatura de dados no SMB"	Título: "fix signededness bug in smb_direct_prepare_negotiation()"; descrição: cast signed/unsigned → heap overflow	CONTRADITÓRIA AOS DADOS
4	"CVE-2021-3847/3864: Escalada de privilégios via OverlayFS e manipulação de dump"	Descrições: OverlayFS (3847) e dumpable/core dump (3864)	SUSTENTADA PELOS DADOS
5	"Todas as vulnerabilidades são críticas"	`Severity = HIGH` em todas	PARCIALMENTE SUSTENTADA
5	CVE-2025-38421 como "Out-of-Bounds Read/Write"	Descrição: double free (CWE-415)	CONTRADITÓRIA AOS DADOS
6	"Escalada de privilégios (CVE-2026-31493)"	Descrição: leitura de contexto liberado em fila administrativa RDMA/efa	NÃO SUSTENTADA PELOS DADOS
6	"ferramentas de mitigação como KASAN"	Descrições apresentam KASAN como detector de erro de memória	NÃO SUSTENTADA PELOS DADOS
7	"execução remota de código" para CVE-2026-46279	Descrição: codetag não inicializado em page_ext; sem vetor remoto	NÃO SUSTENTADA PELOS DADOS
7	"Não há correção específica de pacote para linux-libc-dev nesta CVE"	Sem `FixedVersion`; `Status = affected`	SUSTENTADA PELOS DADOS
7	"datas (2026) podem indicar versões futuras do kernel"	`PublishedDate` 2026 nos dados; sem relação com versão do kernel	NÃO SUSTENTADA PELOS DADOS
8	"execução de código remoto" para 68409, 68470, 72098	Descrições: UAF em RX stats, validação de frames de extensão, overflow em FEC	NÃO SUSTENTADA PELOS DADOS
10	CVE-2026-98320 e 98364: "referências de conntrack"	98320: netfilter flowtable/ct (sustentada); 98364: xfrm/net_device (não é conntrack)	PARCIALMENTE SUSTENTADA
11	CVE-2026-9538: "buffer overflow no Perl … via comando infocmp"	Descrição: exaustão de memória em Archive::Tar; `infocmp` pertence a CVE-2025-69720	CONTRADITÓRIA AOS DADOS
11	`util-linux=2.42.*` como versão corrigida	Descrição: "through 2.41.5 and 2.42.2" vulneráveis	CONTRADITÓRIA AOS DADOS
11	`ncurses-bin=6.5-20251213+`	Descrição: "before 6.5-20251213"	SUSTENTADA PELOS DADOS
9	Impactos de 89633, 89638, 89675	IDs hoje `fixed` no JSON atual; títulos coincidem	SUSTENTADA PELOS DADOS (status diverge entre execuções)

Omissões relevantes

- 19 ocorrências não listadas nas partes em que foram apresentadas (detalhe na justificativa), incluindo 14 das 20 CVEs das partes 7 e 9.
- `Status = fix_deferred` de CVE-2026-9538.
- Revisão explícita de `fstab`/opções `X-mount`, principal mitigação derivável das descrições do util-linux, aparece apenas de forma indireta.
- Nenhuma observação sobre o caráter de pacote de desenvolvimento do `linux-libc-dev`.

Informações adicionais apresentadas pelo modelo

Informação	Classificação
"Debian 13.4 (trixie)" (parte 1)	Não consta dos dados; não verificável por esta avaliação
Flags `--allow-downgrades` / `--allow-change-held-packages`	Não constam dos dados; relação com o achado não demonstrada
Patches upstream descritos em nível de código (parte 7)	Coerentes com as descrições, mas não executáveis pelo operador da imagem
"Execução de código remoto" em diversos CVEs	NÃO SUSTENTADA (ver tabela)

Síntese

DeepSeek R1 produziu partes de boa qualidade (2, 6) e demonstrou cautela quanto à inexistência de correção para o kernel, mas apresentou a menor cobertura entre os três modelos, com partes reduzidas a três IDs, e cometeu erros de caracterização que invertem a natureza de duas vulnerabilidades (CVE-2026-43185 e CVE-2026-9538). Impactos remotos e de escalada foram afirmados sem suporte nas descrições. As recomendações alternam entre genéricas e inaplicáveis, com uma versão-alvo contraditória aos dados. As caracterizações incorretas e os impactos sem suporte configuram informação apresentada como fato sem base nos dados.

Resultado

NÃO SATISFATÓRIO (média 5,00 < 7,00)

Qwen 3.5

Critério	Nota
Vulnerabilidades relevantes	8/10
Impacto provável	6/10
Recomendações de correção	6/10
MÉDIA FINAL	6,67/10

Justificativa das notas

Vulnerabilidades relevantes — 8. Cobertura completa das 109 ocorrências, apresentadas em tabelas com ID, pacote(s), `InstalledVersion` e `Severity` (partes 1, 4, 5, 6, 9, 10) ou listas com pacote (demais partes). As repetições são tratadas por agrupamento de pacotes por ID (por exemplo, "CVE-2026-78410: bsdutils" apenas, correto para a parte 1, em que libblkid1 não trazia esse ID). A CRITICAL é destacada (parte 4). Pequenas imprecisões de associação: na parte 3, CVE-2026-78409 é atribuída também a libuuid1 (esse par só constava da parte 4); na

parte 10, CVE-2026-78409 e 78410 são atribuídas a "login, mount" (mount trazia apenas 76642 e 78408 naquela parte); na parte 6, "SMB Server (IBM)" interpreta `IB_SEND_SIGNALED` (InfiniBand) como IBM. O `Status = fix_deferred` de CVE-2026-9538 não é mencionado. A expressão "10 vulnerabilidades críticas de alta gravidade" (parte 6) mistura categorias. A apresentação é concisa e estruturada, atendendo à instrução do prompt.

Impacto provável — 6. Os resumos por CVE "com base na descrição" (partes 5, 6, 8, 9) são, em geral, fiéis: JFS out-of-bounds (38204), double free em AMD PMF (38421), `WARN_ON` (39958), panic sob fuzzing (40025), "divide error" (68174), SVE/SIGKILL (23102), todos presentes nas descrições. Os impactos do util-linux, libacl1, libcurl e systemd-homed também seguem as descrições. Reduzem a nota as afirmações recorrentes de vetor remoto sem suporte: "execução remota ou local de código (RCE)" para o overflow em `infocmp` (partes 3 e 11, ferramenta de linha de comando), "permite execução remota de código" para CVE-2025-68735 (ioctl de driver gráfico, descrito como escalada local), "usuários locais ou atacantes remotos elevem privilégios" para CVE-2021-3847/3864 (descrições: usuário local), "exposição de informações … via /proc" (parte 8, sem base), "ataques de injeção via rede" (parte 7) e "exposto a ataques em nível local e remoto" (parte 10). A afirmação de que as falhas afetam "por consequência, o kernel binário associado (linux-image, linux-modules)" (parte 5) não é sustentada pelo relatório, que lista apenas `linux-libc-dev`.

Recomendações de correção — 6. Pontos fortes: comandos concretos com os pacotes afetados (`apt update && apt upgrade bsdutils libblkid1 curl libacl1 -y`, `apt full-upgrade`); mitigação de configuração derivada das descrições, repetida de forma consistente (revisar `fstab`, desabilitar `X-mount.idmap/owner/subdir`, partes 1, 2, 4, 11); auditoria de fluxos que usem curl para SSH (parte 1); versão-alvo do util-linux corretamente lida das descrições ("posteriores a 2.41.5 ou 2.42.2, conforme especificado nas descrições", parte 10); reconhecimento implícito de que a correção ainda não foi liberada ("imediatamente após a liberação da nova versão", parte 8). Pontos fracos: recomendações inaplicáveis ao objeto analisado (imagem de container) e não sustentadas pelos dados — `reboot` e `uname -r` (parte 5), `systemctl restart networking` (parte 10), "reiniciar o serviço do kernel" (parte 9), atualizar `linux-image`, `linux-headers`, `firmware-linux-non-free` (parte 6), "isolar a interface de rede do módulo Wi-Fi … Bluetooth" (parte 4); na parte 11, "versão posterior à 2.41-5, onde as CVEs 2026 são corrigidas" contradiz a própria leitura correta da parte 10 e a descrição (2.41.5 ainda vulnerável). Em nenhuma parte afirma explicitamente que os dados não trazem versão corrigida.

Principais acertos

- Cobertura integral com tabelas que reproduzem ID, pacote, versão instalada e severidade.
- Impactos por CVE fiéis às descrições nas partes de kernel.
- Mitigação de `fstab`/`X-mount` consistente em quatro partes.
- Leitura correta das versões vulneráveis do util-linux na parte 10.
- Concisão e estrutura compatíveis com o prompt (16 páginas, sem raciocínio exposto).

Principais limitações

- Afirmações de vetor remoto/RCE sem suporte em pelo menos seis pontos.
- Recomendações de reboot, reinício de rede e atualização de kernel binário, que não se aplicam a uma imagem de container e não constam dos dados.
- Inconsistência interna sobre a versão-alvo do util-linux (partes 10 e 11).
- Sem menção a `fix_deferred` nem à inexistência de `FixedVersion`.
- Imprecisões pontuais de associação ID–pacote (partes 3 e 10) e leitura "IBM" na parte 6.

Divergências observadas

Parte	Conteúdo apresentado pelo modelo	Dado de referência	Classificação
3	CVE-2026-78409 atribuída a "libsmartcols1 e libuuid1"	Na parte 3, libuuid1 trazia apenas 76642 e 78408	PARCIALMENTE SUSTENTADA (ID existe para libuuid1 na parte 4)
3, 11	ncurses CVE-2025-69720: "execução remota ou local de código (RCE)"	Descrição: stack overflow em `infocmp` (ferramenta de linha de comando)	PARCIALMENTE SUSTENTADA (local sim; remoto não)
4	"usuários locais ou atacantes remotos elevem privilégios até root" (CVE-2021-3847/3864)	Descrições: "A local user", "An unprivileged local user"	NÃO SUSTENTADA PELOS DADOS (parte remota)
4	"isolar a interface de rede do módulo Wi-Fi … Bluetooth"	Títulos citam ath12k e af_bluetooth; nada no relatório indica uso desses módulos	NÃO SUSTENTADA PELOS DADOS
5	"afetam o pacote linux-libc-dev e, por consequência, o kernel binário associado (linux-image, linux-modules)"	Relatório lista apenas `linux-libc-dev`; `linux-image` não consta	NÃO SUSTENTADA PELOS DADOS
5	`reboot` e verificação por `uname -r`	Objeto é imagem de container; não há kernel no relatório	NÃO SUSTENTADA PELOS DADOS
6	CVE-2025-68735: "permite execução remota de código"	Título: "Privilege escalation via use-after-free in drm/panthor"; descrição: ioctl GROUP_CREATE/DESTROY por userspace malicioso	CONTRADITÓRIA AOS DADOS (vetor)
6	"SMB Server (IBM)" para CVE-2026-31536	Descrição: `IB_SEND_SIGNALED` (InfiniBand)	CONTRADITÓRIA AOS DADOS
6	"linux-image, linux-headers, firmware-linux-non-free"	Não constam dos dados	NÃO SUSTENTADA PELOS DADOS
7	"ataques de injeção via rede" (netfilter nat, GSO)	Descrições: kfree_rcu em ops; skb->prev obsoleto (UAF)	NÃO SUSTENTADA PELOS DADOS
8	"exposição de informações … via /proc"	Não consta das descrições da parte 8	NÃO SUSTENTADA PELOS DADOS
8	Impactos por CVE (xfrm, bnxt, sctp, smb)	Títulos/descrições coincidem (72463 hoje `fixed`)	SUSTENTADA PELOS DADOS
9	Impactos por CVE (SMB client, CIFS setuid, nfsd, AMD KFD, NVMe, ip6mr, PCI lockdown, qla2xxx, KEYS, timers)	IDs hoje `fixed` no JSON atual; títulos/descrições coincidem	SUSTENTADA PELOS DADOS (status diverge entre execuções)
10	"versões posteriores a 2.41.5 ou 2.42.2, conforme especificado nas descrições"	Descrição de CVE-2026-76642	SUSTENTADA PELOS DADOS
10	78409/78410 atribuídas a "login, mount"	mount trazia 76642 e 78408 na parte 10	PARCIALMENTE SUSTENTADA
10	`systemctl restart networking`	Não aplicável/não consta	NÃO SUSTENTADA PELOS DADOS
11	"versão posterior à 2.41-5, onde as CVEs 2026 são corrigidas"	Descrição: 2.41.5 ainda vulnerável; sem `FixedVersion`	NÃO SUSTENTADA PELOS DADOS

Omissões relevantes

- `Status = fix_deferred` de CVE-2026-9538.

- Ausência de observação explícita de que nenhuma ocorrência traz versão corrigida.
- Nenhuma menção ao caráter de pacote de desenvolvimento do `linux-libc-dev` ou à possibilidade de removê-lo.
- Nenhuma observação sobre `User = nobody` ou sobre a dependência do kernel do hospedeiro.

Informações adicionais apresentadas pelo modelo

Informação	Classificação
"Debian 13.x (Trixie)" (parte 1)	Não consta dos dados; não verificável por esta avaliação
Comandos `dpkg -l linux-libc-dev`, monitoramento de `/var/log/kern.log`, `dmesg`, KASAN splats	Coerentes com as descrições (KASAN citado em várias), mas monitoramento de kernel não se aplica à imagem
"Verificação de Hash/Checksums" e "atualização automática"	Genéricas; não derivadas dos dados
"(e passadas, dado o ano 2026 nos IDs)" (parte 2)	Comentário sem consequência; `PublishedDate` 2026 consta dos dados

Síntese

Qwen 3.5 apresentou a melhor combinação de cobertura, estrutura e concisão, com tabelas que reproduzem fielmente os campos do relatório e impactos por CVE aderentes às descrições. As notas de impacto e recomendação são limitadas por um padrão recorrente de extrapolação para vetores remotos e por recomendações operacionais próprias de um host (reboot, reinício de rede, kernel binário) aplicadas a uma imagem de container, além de uma inconsistência interna sobre a versão-alvo do util-linux. As extrapolações de vetor remoto configuram informação apresentada como fato sem suporte nos dados.

Resultado

NÃO SATISFATÓRIO (média 6,67 < 7,00)

---

17. Comparação consolidada

Critério	Granite 4.2	DeepSeek R1	Qwen 3.5
Vulnerabilidades relevantes	7	5	8
Impacto provável	7	5	6
Recomendações de correção	5	5	6
MÉDIA FINAL	6,33	5,00	6,67

---

18. Comparação por critério

Vulnerabilidades relevantes

Granite 4.2 e Qwen 3.5 cobriram as 109 ocorrências; DeepSeek R1 deixou 19 fora das partes correspondentes, com as partes 7 e 9 reduzidas a 3 de 10 IDs. Na precisão das associações, Granite foi o mais rigoroso no tratamento das repetições (explicita que o mesmo CVE aparece em vários pacotes binários e evita dupla contagem); Qwen agrupou corretamente na maior parte das vezes, com duas atribuições deslocadas entre partes (3 e 10); DeepSeek errou a natureza de duas vulnerabilidades (43185 e 9538) e associou util-linux ao systemd. Na representação dos dados, Qwen foi o mais claro (tabelas com versão e severidade); Granite trouxe a mesma informação, mas diluída em raciocínio exposto; DeepSeek alternou entre listas completas e truncadas. Nenhum dos três mencionou

`fix_deferred`. A diferença de uma unidade entre Qwen (8) e Granite (7) decorre da leitura invertida do status na parte 8 de Granite e da clareza da apresentação; a diferença para DeepSeek (5) decorre da cobertura e dos erros de caracterização.

Impacto provável

Granite condicionou o impacto aos pré-requisitos descritos (acesso local, `fstab`, depuração ativa, kernel do hospedeiro) e, com exceção da parte 8, manteve proporcionalidade. Qwen foi fiel às descrições nos resumos por CVE, mas extrapolou vetores remotos em seis pontos e inferiu a afetação do kernel binário sem base no relatório. DeepSeek alternou partes bem sustentadas (2, 6) com afirmações de execução remota e escalada sem suporte, além de duas caracterizações contraditórias. A nota de Granite (7) reflete a melhor sustentação com um erro grave localizado; a de Qwen (6) reflete fidelidade descritiva com extrapolações recorrentes; a de DeepSeek (5) reflete o acúmulo de inferências não sustentadas e erros de caracterização.

Recomendações de correção

Nenhuma das 109 ocorrências tinha `FixedVersion`; a recomendação sustentável era, portanto, mitigação de configuração e acompanhamento, não versão-alvo. Qwen aproximou-se mais disso: comandos concretos, mitigação de `fstab` consistente e leitura correta das versões vulneráveis na parte 10, prejudicados por recomendações de host (reboot, rede, kernel binário) e por uma contradição interna. Granite ofereceu as mitigações mais ricas (host, container, CIFS/NFS, URLs com esquema) e derivou corretamente três versões upstream das descrições, mas inventou outras cinco, afirmou disponibilidade de correção e citou codinome ausente dos dados. DeepSeek foi genérico, com uma versão-alvo contraditória, correções em nível de código inaplicáveis e KASAN como mitigação, embora tenha sido o único a declarar que não havia correção de pacote para o kernel. As notas 6 (Qwen), 5 (Granite) e 5 (DeepSeek) refletem esse balanço: Granite e DeepSeek empatam por razões distintas — Granite por excesso de informação não sustentada, DeepSeek por insuficiência e inaplicabilidade.

---

19. Efeito da divisão em partes

Evidências observadas nos PDFs:

- **Repetição entre partes.** Os quatro CVEs HIGH do util-linux (76642, 78408, 78409, 78410) foram apresentados em seis partes (1, 2, 3, 4, 10 e 11), por pertencerem a nove pacotes binários ordenados alfabeticamente. Os três modelos reanalisaram os mesmos CVEs em cada parte, com impactos e recomendações repetidos; nenhum podia saber que a família completa somava 36 ocorrências de 4 IDs.
- **Inconsistências entre partes.** Granite indicou versões-alvo diferentes para o mesmo util-linux (>2.41.5, ≥2.42.3, ≥2.41.6) e, na parte 2, negou a existência de mitigação de configuração que recomendou nas partes 1 e 4. Qwen leu corretamente as versões vulneráveis na parte 10 e as contradisse na parte 11. DeepSeek nomeou o pacote como "util-linux" na parte 2 e pelos `PkgName` individuais nas demais.
- **Tratamento desigual de achados semelhantes.** DeepSeek produziu análise por CVE completa na parte 6 e listou apenas 3 de 10 nas partes 7 e 9, de conteúdo análogo. Qwen apresentou tabelas em algumas partes e listas em outras.
- **Variação nas recomendações.** As recomendações para o kernel variaram de "atualizar linux-libc-dev" (todos) a "atualizar kernel + reboot" (Qwen), "garantir host patchado" (Granite) e "aplicar patches upstream" (DeepSeek), sem convergência final, porque não houve etapa de consolidação.
- **Perda de visão global.** Contagens como "Total de Vulnerabilidades Detectadas: 10" (Qwen, parte 8) e "10 vulnerabilidades críticas" (parte 6) refletem a parte, não a imagem. Nenhum modelo pôde observar que 62 das 109 ocorrências eram de um único pacote de desenvolvimento, nem que a única ocorrência CRITICAL estava isolada na parte 4, nem que CVE-2025-69720 e CVE-2026-16742 se repetiam entre as partes 3 e 11.
- **Vantagens observáveis.** Com dez itens por parte, Granite e Qwen conseguiram tratar cada CVE individualmente, com impacto e recomendação por ID nas partes de kernel, o que seria improvável com 109

itens em uma única solicitação. A completude de cobertura de dois dos três modelos é compatível com o tamanho reduzido das partes.

Não há evidência nos PDFs de que a divisão tenha causado as extrapolações de vetor remoto ou as versões-alvo inventadas; esses comportamentos ocorrem dentro de partes isoladas e são atribuíveis ao modelo, não à estrutura.

---

20. Objetividade da resposta

Qwen 3.5 e DeepSeek R1 produziram respostas finais diretas. Granite 4.2 incluiu o raciocínio interno em inglês em todas as partes, elevando o relatório a 40 páginas e exigindo que o leitor localize a resposta final no meio de tentativas e reformulações; esse aspecto foi considerado na nota de Vulnerabilidades relevantes (clareza) e de Recomendações (utilidade), sem constituir critério próprio. O tempo de processamento registrado nos PDFs foi de 2.143 s (Granite), 800 s (DeepSeek) e 806 s (Qwen); não compõe a nota.

---

21. Resultado geral

1º — Qwen 3.5 — 6,67 2º — Granite 4.2 — 6,33 3º — DeepSeek R1 — 5,00

> **Qual modelo apresentou maior aderência aos dados disponíveis nesta rodada?**

Qwen 3.5, por combinar cobertura integral, reprodução fiel dos campos (ID, pacote, versão, severidade) e impactos por CVE aderentes às descrições, com menor volume de informação inventada do que Granite 4.2 e maior cobertura e precisão do que DeepSeek R1. Granite 4.2 teve aderência equivalente na identificação, superior na proporcionalidade do impacto, e inferior nas recomendações, onde apresentou versões e afirmações sem suporte.

> **O desempenho de cada modelo foi satisfatório segundo os critérios definidos?**

- **Granite 4.2:** NÃO SATISFATÓRIO (6,33 < 7,00).
- **DeepSeek R1:** NÃO SATISFATÓRIO (5,00 < 7,00).
- **Qwen 3.5:** NÃO SATISFATÓRIO (6,67 < 7,00).

---

22. Conclusão

Nesta terceira rodada, os três modelos locais receberam 109 ocorrências de vulnerabilidade da imagem `fiware/orion` (todas HIGH, uma CRITICAL, nenhuma com versão corrigida disponível), divididas em onze partes processadas de forma independente, e responderam ao mesmo pedido de três itens. Nenhum alcançou a média 7,00 definida como satisfatória. Qwen 3.5 (6,67) e Granite 4.2 (6,33) ficaram próximos do limiar; DeepSeek R1 (5,00) ficou abaixo.

As diferenças observadas concentram-se em três comportamentos. Primeiro, a **cobertura**: dois modelos listaram todas as ocorrências de cada parte, enquanto DeepSeek R1 reduziu partes inteiras a uma fração dos IDs. Segundo, a **fronteira entre dado e inferência**: Granite 4.2 foi o mais cuidadoso ao condicionar impactos, mas preencheu a ausência de `FixedVersion` com versões próprias; Qwen 3.5 reproduziu fielmente os campos, mas estendeu vetores locais a remotos; DeepSeek R1 inverteu a natureza de duas vulnerabilidades. Terceiro, a **adequação ao objeto**: recomendações de reboot, reinício de rede e atualização de kernel binário, presentes sobretudo em Qwen 3.5, não se aplicam a uma imagem de container e não decorrem dos dados; apenas Granite 4.2 observou que falhas de

kernel dependem do hospedeiro. Nenhum modelo registrou o `Status = fix_deferred`, a ausência generalizada de versão corrigida ou o caráter de pacote de desenvolvimento do `linux-libc-dev`, que concentrava 57% das ocorrências apresentadas.

A comparação tem limitações que devem ser reconhecidas. A entrada efetivamente processada no Teste 03 foi reconstruída a partir dos PDFs e difere da preparação descrita (os modelos receberam apenas HIGH/CRITICAL); a referência atual foi coletada em data posterior à execução original, com banco de vulnerabilidades mais recente, de modo que 11 IDs então "afetados" hoje constam como corrigidos e 20 novos IDs não estavam disponíveis aos modelos — essas diferenças foram tratadas como neutras. A análise de controle foi construída sobre um conjunto mais amplo do que o visto pelos modelos, e sua parte comparável restringe-se às seções de severidade CRITICAL e HIGH. As notas refletem a leitura de um único avaliador sobre três relatórios de uma única execução por modelo, sem repetição, e dependem da interpretação de descrições técnicas em inglês. Os resultados restringem-se ao Teste 03, à imagem `fiware/orion`, à preparação em onze partes e ao prompt utilizado, e não devem ser generalizados para outros modelos, imagens ou configurações.

---

23. Rastreabilidade

Item	Registro
Diretório utilizado	`D:\Documentos(D)\Estudos\FATEC\TCC\docx\analise-3`
Imagem analisada	`fiware/orion` (`fiware/orion:latest`, digest `sha256:dc29ec56888ac7d1a81bac6855fefe3cabcabcaec6bd46a3d9934bb875896edf`, criada 2026-04-14, Debian 13.4)
Comando do Trivy	`trivy.exe image -f json -o TRIVY_FIWARE_ORION_TESTE03.json fiware/orion`
Versão do Trivy	0.74.0; banco `trivy-db:2` atualizado em 2026-10-19 19:08:34 UTC
Data/hora da nova coleta	2026-10-19T18:22:33-03:00 (início) a 18:23:05-03:00 (fim); `CreatedAt` 2026-10-19T18:23:04-03:00
Arquivo JSON utilizado	`TRIVY_FIWARE_ORION_TESTE03.json` (31.005.127 bytes, bruto)
Quantidade total de ocorrências	6.663 (1 `Result`)
Removidas por `Status = fixed`	5.522
Restantes	1.141
Distribuição por severidade dos restantes	CRITICAL 3 · HIGH 115 · MEDIUM 604 · LOW 373 · UNKNOWN 46
Distribuição por status dos restantes	affected 1.138 · fix_deferred 2 · will_not_fix 1
Subconjunto comparável à entrada dos modelos	118 ocorrências HIGH/CRITICAL não corrigidas (entrada reconstruída dos PDFs: 109)

Item	Registro
Relatórios avaliados	`TESTE03 - Granite4.2.pdf` (40 p.), `TESTE03 - Deepseek-r1.pdf` (14 p.), `TESTE03 - Qwen3.5.pdf` (16 p.)
Três critérios	Vulnerabilidades relevantes; Impacto provável; Recomendações de correção práticas
Escala	0 a 10 (10 excelente … 0 não atendido); satisfatório se média ≥ 7,00
Pesos	Iguais
Fórmula da média final	(Vulnerabilidades + Impacto + Recomendações) / 3
Análise de controle	`ANALISE_CONTROLE_TESTE03.md`, salva antes da leitura dos PDFs
Cópia do prompt	`PROMPT_COMPARACAO_TESTE03.txt`
Fontes externas	Nenhuma. Não foram consultados internet, NVD, CVE.org, Debian Security Tracker on-line, GitHub, documentação de fornecedores ou outras bases. Verificação auxiliar única: leitura do JSON do Trivy da rodada anterior (`Analise-2/TRIVY_FIWARE_ORION_HIGH_CRITICAL.json`, mesma imagem) para testar se correspondia à entrada original; resultado negativo (579 fixed / 145 restantes)
Integridade	Os três PDFs e o JSON do Trivy não foram alterados; as notas não foram modificadas após o início da comparação consolidada